

NovaTech Solutions Pvt. Ltd.

Password Policy

Document ID: COMP-PASS-001

Version: 2.0

Effective Date: January 2026

Prepared By: Information Security Office

Classification: Internal Use Only

Document Control

Field	Value
Document	Password Policy
Department	Information Security
Version	2.0
Owner	Chief Information Security Officer (CISO)
Review Cycle	Annual
Last Updated	January 2026

Table of Contents

1. Introduction
 2. Password Policy Statement
 3. Purpose
 4. Scope
 5. Roles and Responsibilities
 6. Password Creation Requirements
 7. Password Storage Requirements
-

1. Introduction

Passwords remain one of the primary methods used to authenticate users and protect organizational information systems.

Weak or compromised passwords increase the risk of unauthorized access, data breaches, and service disruption.

This Password Policy establishes minimum requirements for creating, storing, and protecting passwords used to access NovaTech systems and services.

2. Password Policy Statement

NovaTech is committed to protecting organizational information by enforcing secure authentication practices.

All users shall create and maintain passwords that:

- Protect business information.
- Reduce unauthorized access.
- Support secure authentication.
- Comply with organizational security requirements.

Passwords are considered confidential information and must never be disclosed to unauthorized individuals.

3. Purpose

The objectives of this policy are to:

- Establish minimum password standards.
 - Protect user accounts.
 - Reduce the likelihood of credential compromise.
 - Support secure authentication practices.
 - Promote consistent password management across the organization.
 - Support regulatory and contractual security requirements.
-

4. Scope

This policy applies to:

- Employees
- Contractors
- Consultants
- Temporary staff

- Interns
- Third-party users with authorized system access

The policy covers passwords used for:

- Windows workstations
- Linux servers
- Cloud services
- Business applications
- VPN access
- Email systems
- Databases
- Administrative accounts
- Development environments

This policy applies regardless of whether authentication occurs on-premises or remotely.

5. Roles and Responsibilities

Password security is a shared responsibility.

Chief Information Security Officer (CISO)

The CISO is responsible for:

- Approving password standards.
 - Overseeing authentication governance.
 - Reviewing security risks related to credentials.
 - Supporting compliance initiatives.
-

Information Technology Team

Responsible for:

- Implementing password controls.
- Managing authentication systems.
- Supporting password reset procedures.

- Monitoring authentication events.
 - Maintaining identity management systems.
-

Department Managers

Managers should:

- Ensure employees follow password requirements.
 - Report suspected credential misuse.
 - Support security awareness initiatives.
-

Employees

Employees are responsible for:

- Creating strong passwords.
- Protecting credentials.
- Reporting suspected compromise immediately.
- Following this policy.
- Completing required security awareness training.

Passwords should never be shared with coworkers, supervisors, or external parties.

6. Password Creation Requirements

Passwords should provide sufficient protection against unauthorized access.

General Requirements

Passwords should:

- Be unique for each business account.
- Be difficult to guess.
- Not contain obvious personal information.
- Not be reused across unrelated services.
- Remain confidential.

Simple or predictable passwords should not be used.

Password Length

Passwords should contain an appropriate number of characters to provide effective protection.

Longer passwords generally provide stronger resistance against unauthorized guessing and automated attacks.

Complexity

Strong passwords should include a combination of different character types where supported, such as:

- Uppercase letters
- Lowercase letters
- Numbers
- Special characters

Users are encouraged to create memorable passphrases rather than relying on short, complex words alone.

Prohibited Passwords

Users should not use passwords containing:

- Their name
- Employee ID
- Username
- Company name
- Birth dates
- Telephone numbers
- Common dictionary words
- Sequential numbers
- Keyboard patterns

Examples of weak passwords include:

- Password123
- Welcome123

- Admin123
 - CompanyName2026
-

Password Uniqueness

Business passwords should not be reused across:

- Personal email accounts
- Social media accounts
- Online shopping websites
- Banking services
- Third-party business applications without approval

Unique credentials reduce the impact of credential compromise.

Temporary Passwords

Temporary passwords issued by administrators should:

- Be changed immediately after first successful login.
- Not be reused.
- Be communicated securely.

Temporary credentials should expire according to organizational procedures.

7. Password Storage Requirements

Passwords should be protected throughout their lifecycle.

Storage Rules

Passwords should never be stored in:

- Plain text files
- Sticky notes
- Shared spreadsheets
- Email messages
- Chat applications

- Printed documents

Unauthorized storage significantly increases security risk.

Approved Storage

Where credential storage is necessary, users should utilize approved password management solutions.

Password managers should:

- Encrypt stored credentials.
- Require strong authentication.
- Protect synchronization data.
- Support secure password generation.

Only organization-approved password managers should be used for business credentials.

System Storage

Applications and systems should:

- Protect stored authentication credentials using approved security mechanisms.
- Prevent unauthorized access to credential stores.
- Restrict administrative access.
- Support secure authentication processes.

Authentication systems should be reviewed periodically.

Credential Sharing

Passwords should never be shared through:

- Email
- Messaging platforms
- Telephone conversations
- Printed documents
- Shared notes

When temporary administrative access is required, approved privileged access procedures should be followed instead of sharing passwords.

Credential Protection

Users should:

- Enter passwords only into trusted systems.
- Verify website addresses before authentication.
- Avoid entering passwords on unknown or suspicious websites.
- Report suspected credential theft immediately.

Protecting credentials is essential to maintaining organizational security.

Revision History

Version	Date	Description
1.0	January 2024	Initial Password Policy
1.5	July 2025	Added Password Storage and Credential Protection Requirements
2.0	January 2026	Updated Password Creation Standards and Organizational Responsibilities

8. Password Changes

Passwords should be changed whenever there is reason to believe they have been compromised.

Routine password changes should follow organizational authentication standards.

Mandatory Password Changes

Users should change their passwords immediately if:

- A compromise is suspected.
- Credentials have been shared accidentally.
- A phishing attack may have exposed credentials.
- An administrator requires a reset.
- Temporary passwords have been issued.

Prompt password changes reduce the risk of unauthorized access.

Administrative Resets

When administrators reset passwords:

- User identity should be verified.
 - Temporary passwords should be communicated securely.
 - Users should change temporary passwords after first login.
 - Reset activities should be recorded.
-

9. Password History

Password reuse increases the risk of credential compromise.

Authentication systems should prevent immediate reuse of previous passwords where technically supported.

Password Reuse

Users should not:

- Reuse recently used passwords.
- Alternate between a small number of passwords.
- Make only minor changes to previous passwords.

Examples of weak modifications include:

- Password2025 → Password2026
 - Welcome1 → Welcome2
-

Password Expiration

Password expiration requirements depend on:

- System sensitivity
- Risk assessment
- Authentication technology
- Regulatory obligations

Accounts protected by strong authentication controls may follow different password rotation practices than legacy systems.

10. Multi-Factor Authentication (MFA)

Multi-Factor Authentication strengthens account protection by requiring more than one authentication factor.

MFA Requirements

MFA should be enabled for:

- Administrative accounts
- Cloud platforms
- Remote access
- VPN connections
- Financial systems
- Identity management platforms

Additional business systems may require MFA based on risk.

Authentication Factors

Approved authentication factors may include:

- Password
- Mobile authenticator application
- Hardware security token
- Biometric verification

Multiple authentication factors significantly reduce credential-based attacks.

Lost Authentication Devices

Users should report lost authentication devices immediately.

Administrators should:

- Disable compromised authentication methods.
- Verify user identity.
- Issue replacement authentication credentials.

11. Password Managers

Password managers improve password security by generating and protecting unique credentials.

Approved Password Managers

Business credentials should be stored only in organization-approved password management solutions.

Approved solutions should support:

- Encryption
- Secure synchronization
- Strong authentication
- Secure credential generation
- Administrative management

Password Generation

Users are encouraged to generate passwords using approved password management tools.

Automatically generated passwords generally provide stronger protection than manually created passwords.

Shared Vaults

Where shared credentials are operationally necessary:

- Shared vaults should be used.
- Access should be restricted.
- Activity should be logged.
- Permissions should be reviewed regularly.

Credential sharing outside approved password management systems is prohibited.

12. Account Lockout

Account lockout mechanisms reduce the effectiveness of password guessing attacks.

Lockout Conditions

Authentication systems should respond appropriately to repeated unsuccessful login attempts.

Protective actions may include:

- Temporary account lockout
- Progressive authentication delays
- Additional verification requirements
- Security alerts

Specific thresholds are defined within system configuration standards.

Unlock Procedures

Locked accounts should be restored through approved identity verification procedures.

Users should not attempt to bypass account protection mechanisms.

13. Service Accounts

Service accounts support automated system processes.

Because these accounts often operate without interactive users, they require additional protection.

Service Account Requirements

Service accounts should:

- Be documented.
- Have assigned owners.
- Follow the principle of least privilege.
- Use strong credentials.
- Be monitored regularly.

Unused service accounts should be removed promptly.

Credential Management

Service account credentials should:

- Be protected securely.
 - Not be embedded in source code.
 - Be accessible only to authorized administrators.
 - Be rotated according to organizational procedures where supported.
-

14. Shared Accounts

Individual accountability is a fundamental security principle.

Shared accounts should generally be avoided.

Exceptions

Where shared accounts are operationally necessary:

- Business justification should exist.
- Management approval should be documented.
- Access should be restricted.
- Usage should be monitored.
- Credentials should be protected.

Whenever practical, named individual accounts should be used instead.

15. Privileged Accounts

Privileged accounts have elevated access and therefore require enhanced protection.

Administrative Accounts

Administrative accounts should:

- Be assigned only when necessary.
- Be approved by management.
- Use Multi-Factor Authentication.
- Be monitored continuously.
- Be reviewed periodically.

Administrative privileges should not be used for routine business activities.

Privileged Access

Users performing administrative tasks should:

- Use dedicated privileged accounts.
 - Log administrative activities where supported.
 - Avoid sharing administrative credentials.
 - Disconnect privileged sessions when work is complete.
-

Privileged Account Reviews

The Information Technology and Information Security teams should periodically review:

- Assigned administrators
- Privileged permissions
- Dormant privileged accounts
- Access approvals

Unnecessary administrative privileges should be removed promptly.

16. Remote Access Authentication

Remote access introduces additional security risks and requires stronger authentication controls.

Remote Authentication Requirements

Remote users should:

- Authenticate using approved methods.
 - Use Multi-Factor Authentication where required.
 - Connect through authorized remote access solutions.
 - Protect company devices while working remotely.
-

Public Networks

Users connecting from public networks should:

- Verify secure connections.
- Avoid using untrusted computers.
- Protect authentication credentials.
- Report suspicious activity immediately.

Public wireless networks should be used with appropriate security precautions.

Remote Device Security

Remote devices should:

- Be protected by passwords or other approved authentication methods.
- Use approved endpoint protection.
- Receive operating system updates.
- Encrypt sensitive business information where required.

Compromised remote devices should be reported immediately.

17. Password Management Best Practices

Users should:

- Create unique passwords for every business account.
- Use approved password managers.
- Enable Multi-Factor Authentication whenever available.
- Never share passwords.
- Protect authentication devices.
- Report suspicious login activity.
- Verify websites before entering credentials.
- Lock workstations when unattended.
- Follow organizational security procedures.
- Complete required security awareness training.

Strong password practices significantly reduce the risk of unauthorized access.

18. Password Reset Procedures

Password reset procedures should ensure that only authorized users regain access to their accounts.

Identity verification shall be completed before a password reset is performed.

User Verification

Before resetting a password, administrators should verify the user's identity using approved verification procedures.

Verification may include:

- Employee identification
- Registered email address
- Multi-Factor Authentication verification
- Approved identity verification process

Password resets should not be performed without adequate identity validation.

Temporary Passwords

Temporary passwords issued during a reset should:

- Be communicated securely.
 - Expire according to organizational procedures.
 - Be changed immediately after first successful login.
 - Never be reused.
-

Self-Service Password Reset

Where supported, users may reset their passwords using approved self-service functionality.

Self-service password reset solutions should:

- Verify user identity.
 - Support Multi-Factor Authentication.
 - Generate secure temporary credentials where applicable.
 - Record password reset activities.
-

19. Password Auditing & Monitoring

Authentication activities should be monitored to identify suspicious or unauthorized behavior. Monitoring supports early detection of credential compromise.

Authentication Logging

Systems should record authentication events including:

- Successful logins
- Failed login attempts
- Password changes
- Password resets
- Account lockouts
- Administrative authentication events

Logs should be protected against unauthorized modification.

Security Monitoring

The Information Security Team should monitor for:

- Repeated failed login attempts
- Unusual login locations
- Suspicious authentication patterns
- Excessive password reset requests
- Privileged account activity

Significant security events should be investigated promptly.

Periodic Reviews

Authentication controls should be reviewed periodically to evaluate:

- Password policy compliance
- Privileged account usage
- Service account management
- MFA adoption

- Dormant accounts

Findings should be documented and corrective actions tracked.

20. Security Awareness

Technology alone cannot protect organizational information.

Employees should understand how to protect authentication credentials.

Mandatory Training

Training should include:

- Strong password creation
- Password manager usage
- Multi-Factor Authentication
- Phishing awareness
- Social engineering
- Credential protection
- Secure remote work
- Incident reporting

Training completion should be recorded.

User Responsibilities

Users should:

- Keep passwords confidential.
- Verify websites before entering credentials.
- Protect authentication devices.
- Lock unattended workstations.
- Report suspected credential compromise immediately.

Responsible user behavior significantly improves organizational security.

21. Policy Violations

Failure to comply with this Password Policy may increase organizational security risks. Policy violations should be investigated according to organizational procedures.

Examples of Violations

Examples include:

- Sharing passwords
 - Storing passwords insecurely
 - Using unauthorized password managers
 - Circumventing authentication controls
 - Failing to report credential compromise
 - Reusing prohibited passwords
 - Attempting unauthorized access
-

Corrective Actions

Depending on severity, corrective actions may include:

- Additional security awareness training
 - Password reset
 - Temporary access suspension
 - Formal investigation
 - Disciplinary action in accordance with Human Resources policies
-

22. Policy Exceptions

Exceptions should be granted only when justified by legitimate business requirements.

Exception Requests

Requests should include:

- Business justification
- Affected systems
- Risk assessment

- Proposed compensating controls
- Requested duration

Exceptions require documented approval from authorized management and the Information Security function.

Exception Review

Approved exceptions should be reviewed periodically.

Expired exceptions should be:

- Removed,
 - Renewed through formal approval, or
 - Replaced with compliant authentication controls.
-

23. Continuous Improvement

Password management practices should evolve as technology and threats change.

Improvement Activities

NovaTech should regularly:

- Review authentication technologies.
- Strengthen password standards.
- Increase MFA adoption.
- Improve password reset procedures.
- Enhance monitoring capabilities.
- Review authentication incidents.
- Update employee training.
- Improve identity management processes.

Continuous improvement reduces authentication-related risk.

24. Definitions

Term	Definition
Authentication	Process of verifying a user's identity
Password	Secret credential used for authentication
Passphrase	A longer sequence of words or characters used for authentication
MFA	Multi-Factor Authentication using multiple independent verification methods
Privileged Account	Account with elevated administrative permissions
Service Account	Non-interactive account used by applications or services
Password Manager	Approved software used to securely store and generate passwords
Account Lockout	Temporary restriction after repeated failed authentication attempts

25. Frequently Asked Questions

Q1. Can I share my password with my manager?

No. Passwords must never be shared with managers, coworkers, contractors, or third parties.

Q2. What should I do if I think my password has been compromised?

Change your password immediately and report the incident to the Information Technology or Information Security Team.

Q3. Should I use the same password for multiple systems?

No. Each business account should use a unique password.

Q4. Are password managers allowed?

Yes. Only organization-approved password managers should be used for business credentials.

Q5. Why is Multi-Factor Authentication important?

MFA significantly reduces the risk of unauthorized account access by requiring multiple forms of identity verification.

Q6. Can passwords be stored in spreadsheets or documents?

No. Passwords should only be stored using approved password management solutions.

Q7. What happens if my account is locked?

Follow the approved account recovery or password reset process after identity verification.

Q8. Why are privileged accounts treated differently?

Privileged accounts have elevated permissions and therefore require stronger security controls and monitoring.

Q9. What should I do if I receive a suspicious login notification?

Verify your recent activity. If the login was not initiated by you, report it immediately and change your password.

Q10. How often is the Password Policy reviewed?

The policy is reviewed at least annually and whenever significant changes to authentication technology, security risks, or regulatory requirements occur.

Revision History

Version	Date	Description
1.0	January 2024	Initial Password Policy
1.5	July 2025	Added Password Monitoring, MFA Guidance, and Service Account Controls
2.0	January 2026	Expanded Password Reset Procedures, Governance, Continuous Improvement, and FAQ

Related Documents

- Information Security Policy (COMP-SEC-001)
- GDPR Data Protection Policy (COMP-GDPR-001)

- Employee Code of Conduct (HR-COC-004)
- Infrastructure Guide (TECH-INFRA-001)
- Incident Response Process (OPS-IR-001)
- Employee Handbook (HR-HBK-001)